

Documentation_RGPD

RGPD - Audit de conformité X-corp

Sommaire

1. [Concepts clés du RGPD](#)
 2. [Registre des traitements](#)
 3. [Analyse d'impact - DPIA](#)
 4. [Gestion d'une violation de données](#)
 5. [Audit de conformité](#)
-

Concepts clés du RGPD

CF - RGPD - RAPPORT



de 5



RGPD : Règlement Général sur la Protection des Données

X-Corp:

Acteurs du traitement:

<u>Acteur</u>	<u>Rôle chez X-Corp</u>
Responsable du traitement	X-Corp, qui détermine les finalités (personnalisation d'offres, suivi de patients, suivi pédagogique) et les moyens (DataManage, MarketInsight, AutoMail) des traitements réalisés pour ses clients RetailCo, HealthMed et EduLearn.
Sous-traitants	CloudSecure (hébergement et stockage cloud sécurisé des données) et AdBoost (diffusion de publicité ciblée à partir de segments transmis par X-Corp). Ces prestataires traitent des données pour le compte de X-Corp et doivent être liés par un contrat de sous-traitance conforme à l'article 28 du RGPD.
Personnes concernées	Les clients de RetailCo (≈800 000), les patients de HealthMed (≈500 000) et les utilisateurs d'EduLearn (≈300 000), dont les données transitent par les outils de X-Corp.
DPO (Délégué à la Protection des Données)	Un DPO a été désigné chez X-Corp ; il supervise la conformité, conseille sur les DPIA et constitue le point de contact avec la CNIL et les personnes concernées.
Autorité de contrôle	La CNIL, le siège social de X-Corp se situant à Paris.

Registre des traitements

Introduction

Dans cette partie du projet, le travail demandé consiste à compléter le registre des traitements de l'entreprise fictive X-corp. Le registre est un document important, car il permet de recenser les traitements de données personnelles réalisés par l'entreprise et de mieux comprendre comment les données sont utilisées dans son activité.

Compréhension de l'entreprise

X-corp est une entreprise spécialisée dans les technologies et les services numériques. Elle est basée à Paris, compte 150 employés et développe trois outils principaux : DataManage, MarketInsight et AutoMail. Avant de remplir le registre, il faut d'abord comprendre le fonctionnement général de X-corp. L'entreprise travaille avec trois clients principaux : RetailCo, HealthMed et EduLearn. RetailCo est une chaîne de magasins. HealthMed intervient dans le domaine de la santé. EduLearn est une plateforme d'e-learning. Ces trois clients permettent de voir que X-corp traite des données dans des contextes très différents, ce qui rend l'analyse plus intéressante. Le sujet précise aussi que X-corp travaille avec CloudSecure pour le stockage cloud et avec AdBoost pour la publicité digitale ciblée. Ces partenaires doivent donc être pris en compte dans la réflexion sur les traitements de données.

Méthode utilisée

Pour réaliser ce travail, la première étape a été de relire le sujet afin d'identifier les différents traitements de données décrits dans le cas pratique. Ensuite, les informations ont été classées de manière simple : les personnes concernées, les données utilisées, la finalité du traitement, la durée de conservation, les destinataires et les mesures de sécurité. Cette méthode permet d'obtenir un registre clair, logique et facile à expliquer à l'oral. Elle permet aussi de bien distinguer les traitements les plus sensibles de ceux qui présentent moins de risques.

Rôle de X-corp

Dans le cas étudié, X-corp agit surtout comme sous-traitant, car elle traite les données pour le compte de ses clients. RetailCo, HealthMed et EduLearn sont donc plutôt les responsables de traitement, car ce sont eux qui définissent la finalité de l'utilisation des données. En parallèle, X-corp peut aussi avoir ses propres traitements internes, par exemple pour sa gestion commerciale, sa gestion RH ou la sécurité de ses systèmes. Cela montre qu'une entreprise peut avoir plusieurs rôles en matière de protection des données.

Registre simplifié des traitements

ST-01 — Gestion des clients RetailCo : personnes concernées, clients RetailCo ; données utilisées, nom, adresse, e-mail, téléphone, historique d'achats, préférences ; finalité,

personnaliser les offres et promotions ; conservation, 5 ans après le dernier contact.

ST-02 — Campagnes AutoMail : personnes concernées, clients et prospects RetailCo ; données utilisées, e-mails, préférences marketing, comportement, consentement ; finalité, envoyer des campagnes ciblées ; conservation, à préciser.

ST-03 — Analyse marketing RetailCo : personnes concernées, clients RetailCo ; données utilisées, historique d'achats, segmentation, préférences ; finalité, analyse marketing et recommandations ; conservation, 5 ans après le dernier contact.

ST-04 — Suivi des patients HealthMed : personnes concernées, patients HealthMed ; données utilisées, nom, adresse, e-mail, téléphone, historique médical, prescriptions ; finalité, suivi des traitements et rappel de rendez-vous ; conservation, 10 ans après la fin du traitement médical.

ST-05 — Analyse de l'usage EduLearn : personnes concernées, utilisateurs EduLearn ; données utilisées, identifiants, e-mail, parcours d'apprentissage, résultats d'examen ; finalité, amélioration du parcours et suivi des progrès ; conservation, 2 ans après la fin d'utilisation.

Ce tableau permet d'avoir une vue d'ensemble rapide des traitements principaux repérés dans le sujet.

Détail des traitements

RetailCo : le premier traitement concerne RetailCo. X-corp traite les données de ses clients à travers son outil DataManage. Les données concernées sont les noms, adresses, e-mails, numéros de téléphone, historiques d'achats et préférences produits. L'objectif est de personnaliser les offres commerciales et d'améliorer l'expérience client. La conservation prévue est de 5 ans après le dernier contact. Ce traitement reste classique, mais il implique un volume important de données clients.

AutoMail : le deuxième traitement important concerne AutoMail, qui permet de créer des campagnes e-mailing ciblées selon le comportement des utilisateurs. Ce point est particulièrement intéressant, car le sujet précise qu'il existe déjà des difficultés dans la gestion et la documentation des consentements marketing. Cela veut dire que le traitement n'est pas seulement technique. Il pose aussi une vraie question d'organisation, car il faut être capable de prouver qu'un utilisateur a bien accepté de recevoir ces messages.

HealthMed : le traitement HealthMed est le plus sensible du registre, car il porte sur des données de santé. Les données utilisées concernent notamment l'identité des patients, leurs coordonnées, leur historique médical et leurs prescriptions. La finalité est de suivre les traitements, rappeler les rendez-vous et personnaliser les conseils de santé. La durée de conservation est de 10 ans après la fin du traitement médical. C'est clairement le traitement qui demande le plus de vigilance dans le cadre du projet.

EduLearn : le traitement EduLearn concerne l'analyse de l'usage de la plateforme d'apprentissage. Les données collectées sont les identifiants utilisateurs, les e-mails, les

parcours d'apprentissage et les résultats d'examen. L'objectif est d'améliorer les parcours, recommander des cours et suivre les progrès des utilisateurs. La durée de conservation indiquée est de 2 ans après la fin de l'utilisation de la plateforme. Ce traitement est moins sensible que celui de HealthMed, mais il reste important car il touche au suivi de l'activité des utilisateurs.

Mesures de sécurité

Le sujet mentionne déjà plusieurs mesures de sécurité mises en place chez X-corp. On retrouve la pseudonymisation des données sensibles, le chiffrement des données en transit et au repos, l'authentification à deux facteurs et le contrôle d'accès basé sur les rôles. Ces éléments montrent que l'entreprise a déjà mis en place une base de sécurité technique, même si cela ne suffit pas à garantir à lui seul une conformité complète.

Points sensibles repérés

Le premier point sensible concerne la gestion des consentements pour le marketing via AutoMail. Le deuxième point sensible concerne les demandes de droit d'accès, puisque X-corp en reçoit régulièrement. Cela suppose une organisation claire pour retrouver les données et répondre dans les délais. Le troisième point sensible concerne les violations de données, car une fuite de données mineure a déjà eu lieu dans l'entreprise. Cet incident montre qu'il existe encore des faiblesses dans la réponse à incident.

Ce qu'il faut retenir

Le registre permet de voir rapidement quels traitements existent chez X-corp, quelles données sont concernées et où se trouvent les principaux risques. Dans ce projet, le traitement le plus critique est celui de HealthMed, car il concerne des données de santé. Le traitement le plus problématique sur le plan organisationnel est celui d'AutoMail, à cause de la gestion des consentements marketing. Les demandes de droit d'accès et l'incident de sécurité passé montrent aussi que la conformité ne repose pas uniquement sur la technique, mais aussi sur les procédures internes et la capacité de l'entreprise à réagir correctement.

Conclusion

Pour ce job 2, le travail a consisté à identifier les traitements de données de X-corp et à les organiser dans un registre simple et compréhensible. Ce registre sert ensuite de base pour la suite du projet, notamment l'analyse d'impact, la gestion d'une violation de données et l'audit de conformité. L'idée principale est que le registre n'est pas seulement un tableau administratif. C'est surtout un outil qui aide à comprendre le fonctionnement de l'entreprise, à repérer les traitements sensibles et à préparer une meilleure conformité au RGPD.

[Sommaire](#)

Analyse d'impact - DPIA

• Qu'est-ce qu'une DPIA ?

La DPIA (*Data Protection Impact Assessment*, ou AIPD en français : Analyse d'Impact relative à la Protection des Données) est une étude préalable obligatoire dans certains cas, prévue par l'**article 35 du RGPD**. Elle vise à évaluer, avant de mettre en œuvre un traitement, les risques qu'il fait peser sur les droits et libertés des personnes concernées, et à définir les mesures pour réduire ces risques.

Ce n'est pas une simple formalité : c'est un outil de gestion du risque, comparable à une étude d'impact environnementale, mais appliquée aux données personnelles.

• Quand une DPIA est-elle obligatoire ?

Une DPIA (Analyse d'Impact relative à la Protection des Données) est une étude visant à évaluer les risques d'un traitement de données. C'est un outil de gestion du risque préalable à un traitement de données visant à protéger les droits et les libertés des personnes dont les données exposées. Une DPIA est obligatoire si elle remplit 2 des 9 critères suivants :

1. Évaluation ou notation des personnes (scoring)
2. Décision automatisée avec effet juridique ou significatif
3. Surveillance systématique
4. Collecte de données sensibles ou à caractère hautement personnel
5. Collecte de données à grande échelle
6. Croisement ou combinaison d'ensembles de données
7. Personnes vulnérables (patients, personnes âgées, mineurs...)
8. Usage innovant ou application de nouvelles solutions technologiques
9. Exclusion du bénéfice d'un droit ou d'un contrat pour la personne concernée

Nous décidons de réaliser une DPIA pour l'un des projets de X-Corp :

1 - Contexte :

Description du traitement : Envoie des rappels de rendez-vous à ses patients.

Ce traitement de données remplit trois des 9 critères :

- Collecte de données sensibles ou à caractère hautement personnel (Historique médical, prescriptions)
- Personnes vulnérables (patients)
- Collecte de données à grande échelle (500 000 patients)

X-Corp est sous-traitant car il exécute techniquement le traitement (envoi des rappels, hébergement, sécurité) sur instruction de Hea

Finalités : AutoMail sert à prévenir les patients de HealthMed de la date de leur rendez-vous, pour éviter les rendez-vous manqués et assurer un bon suivi médical.

Enjeux : les données traitées sont sensibles et concernent beaucoup de patients, donc un accès non autorisé aurait des conséquences graves, aussi bien pour les patients que pour la responsabilité de HealthMed et X-Corp.

2 - Mesures

Proportionnalité et minimisation des données : seules les informations nécessaires à l'envoi du rappel sont utilisées, à savoir l'identité, les coordonnées, la date et le motif du rendez-vous. Le dossier médical, les diagnostics et les prescriptions ne passent pas par AutoMail et restent uniquement dans le système de HealthMed.

3 - Risques

Vraisemblance et gravité des atteintes possibles : si ces données fuyaient, les conséquences seraient graves à cause de leur caractère médical, mais ce risque reste peu probable tant que les mesures de sécurité actuelles (chiffrement, hébergement HDS, contrôle d'accès) sont bien respectées.

4 - Validation

Plan d'action : mettre la double authentification sur tous les accès administrateur, ajouter des vérifications avant l'envoi des messages, et rendre la notice d'information plus claire pour les patients.

[Sommaire](#)

Gestion d'une violation de données

AutoMail - HealthMed

Scénario retenu : un hacker se connecte à la console d'administration d'AutoMail à l'aide d'identifiants compromis par phishing. Il accède pendant plusieurs heures à la base des envois programmés pour HealthMed avant que l'incident ne soit détecté. Environ 2 000 patients sont concernés, avec exposition de leur identité, de leurs coordonnées et du motif de leur rendez-vous.

Étape 1 - Détection

- Une alerte de connexion inhabituelle (horaire atypique, volume de requêtes anormal) est remontée par le système de supervision de X-corp, ce qui déclenche l'analyse de l'incident.

Étape 2 - Qualification

- L'atteinte relève de la confidentialité des données, au sens de l'article 4.12 du RGPD : il s'agit d'un accès non autorisé à des données personnelles, sans altération ni perte des données elles-mêmes.

Étape 3 - Évaluation du risque

- Le risque est élevé pour les personnes concernées, en raison de la nature sensible des données (motif de rendez-vous, donnée de santé au sens de l'article 9), du volume important de patients touchés et de leur identifiabilité directe. Les conséquences potentielles incluent la divulgation d'informations médicales, un risque de stigmatisation et une atteinte à la vie privée.

Étape 4 - Notification

- Le risque étant élevé, une double notification est requise. HealthMed, en tant que responsable de traitement, notifie la CNIL sous 72 heures, X-corp lui transmettant sans délai tous les éléments nécessaires conformément à son obligation de sous-traitant (article 33.2). HealthMed informe également individuellement les 1 200 patients concernés, avec une description de l'incident, des données touchées et des mesures prises.

Étape 5 - Correction et documentation

- Les mesures immédiates comprennent la révocation des identifiants compromis et le changement des mots de passe d'administration. Les mesures durables portent sur la généralisation de l'authentification à deux facteurs, le renforcement de la détection des connexions anormales et une formation anti-phishing du personnel technique de X-corp de HealthMed. L'incident est consigné dans le registre interne des violations de X-corp, avec le détail des mesures correctives engagées.

C'est précisément pour vérifier que ces principes sont effectivement respectés dans la durée, et non uniquement au moment de la conception des traitements, qu'il est nécessaire de procéder à un audit de conformité global de X-Corp, permettant d'évaluer traitement par traitement l'adéquation entre les pratiques réelles et les obligations posées par le RGPD.

[Sommaire](#)

Audit de conformité

X-Corp, éditeur des solutions DataManage, MarketInsight et AutoMail, traite des données pour le compte de trois clients principaux (RetailCo, HealthMed, EduLearn), dont des données de santé à grande échelle. L'audit révèle une organisation dotée de fondations

solides — DPO désigné, mesures de sécurité techniques avancées (chiffrement AES-256, RBAC, authentification à deux facteurs), DPIA menées avant chaque lancement produit — mais présentant des non-conformités récurrentes sur la gouvernance du consentement, la sous-traitance et le pilotage des risques de sécurité.

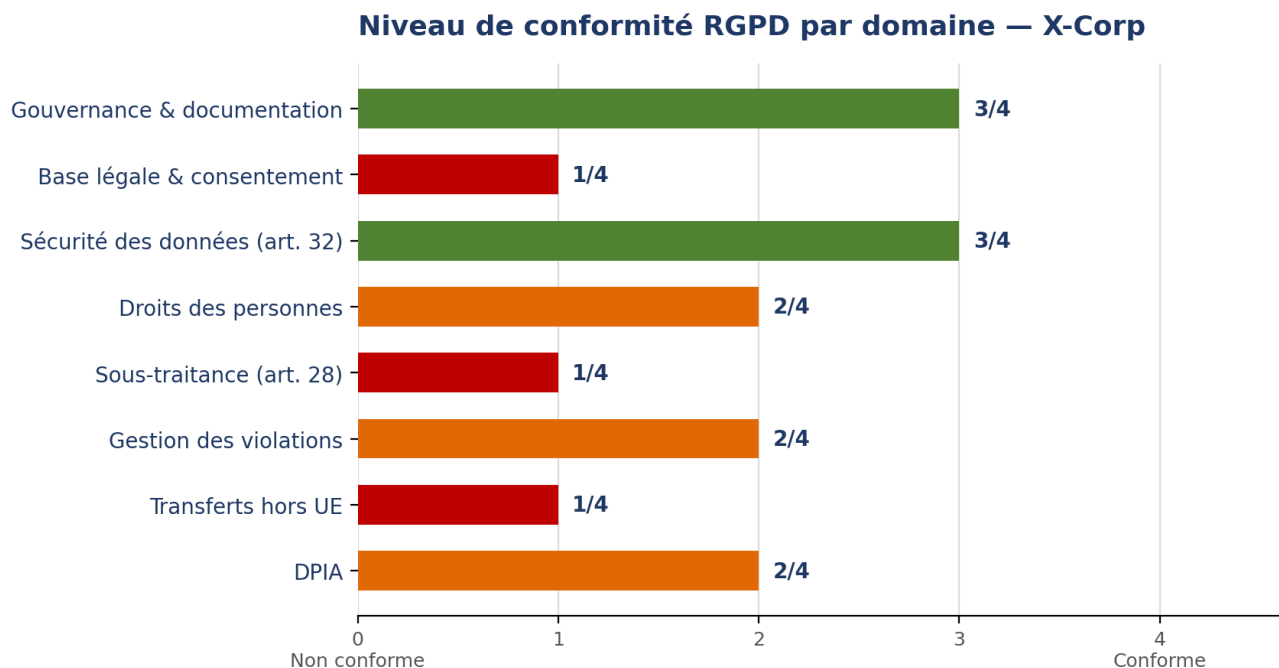
1. Méthodologie et périmètre

Référentiel : articles 5, 6, 9, 12 à 23, 28, 30, 32, 33-34 et 35 du RGPD ; guides et outils de conformité de la CNIL.

Périmètre : les trois produits de X-Corp (DataManage, MarketInsight, AutoMail) et les traitements réalisés pour RetailCo, HealthMed et EduLearn.

Méthode : analyse documentaire du dossier d'audit, élaboration du registre des traitements, réalisation d'une DPIA sur le traitement le plus à risque, simulation d'une violation de données.

2. Synthèse par domaine de conformité



Domaine	Status	Résultat
Gouvernance et documentation	Conforme	DPO désigné, DPIA réalisées avant chaque lancement produit, politique de conservation revue tous les 2 ans. -> Point d'amélioration : le registre des traitements ne couvre pour l'instant que 4 traitements identifiés; les traitements internes (RH, comptabilité...) restent à cartographier.

Domaine	Status	Résultat
Base légale et consentement	Non-Conforme	Le consentement est utilisé comme base légale quasi systématique, y compris là où l'exécution d'un contrat (suivi médical HealthMed) ou l'intérêt légitime (analyses MarketInsight) seraient plus adaptés. Difficultés confirmées de gestion et de documentation des consentements marketing (AutoMail).
Sécurité des données	Conforme	Mesures techniques solides : pseudonymisation, chiffrement AES-256, authentification à deux facteurs, contrôle d'accès par rôles (RBAC). Toutefois que le MFA n'est pas encore généralisé à tous les comptes sensibles.
Droit des personnes	Partiellement Conforme	Volume important de demandes de droit d'accès (50 à 100/mois) sans procédure formalisée et outillée décrite dans le dossier d'audit, ce qui fait peser un risque de non-respect du délai légal d'un mois, en particulier pour les données de santé.
Sous-traitance	Non-Conforme	CloudSecure et AdBoost sont identifiés comme sous-traitants mais aucun élément du dossier ne confirme l'existence de contrats de sous-traitance conformes, ni la localisation exacte des données (transferts hors UE non identifiés).
Gestion des violations	Partiellement Conforme	Un incident réel passé a révélé des lacunes dans le processus de réponse. La simulation effectuée a permis de documenter un scénario de bout en bout (détection à notification), mais ce processus reste à formaliser officiellement.
Transferts hors-UE	Non-Conforme	Aucune information disponible sur la localisation des serveurs de CloudSecure ni sur d'éventuels transferts vers AdBoost hors UE. Point aveugle à lever en priorité.
DPIA	Partiellement Conforme	Une DPIA est réalisée avant chaque nouveau produit, mais sans méthodologie formalisée démontrée

→ Hétérogénéité des traitements : X-Corp traite des données pour le compte de trois secteurs très différents (retail, santé, éducation) avec un niveau de sensibilité variable, mais applique des mesures de sécurité globalement homogènes plutôt qu'une gradation par niveau de risque.

→ Facteur humain : identifié comme vecteur d'attaque vraisemblable dans la simulation d'incident et cohérent avec l'absence de formation anti-phishing mentionnée dans le dossier.

→ Sous-outillage des processus RGPD : les difficultés de gestion des consentements marketing et le volume de demandes de droit d'accès traduisent un besoin d'outillage (plateforme de gestion des consentements, portail self-service pour les demandes de droits).

3. Plan d'action

1. Priorité: Critique

→ Base légale reposant quasi exclusivement sur le consentement, mal adaptée à certains traitements.

-> Action recommandée: Appliquer la base légale appropriée en fonction du traitement spécifique (contrat pour le suivi médical, intérêt légitime documenté pour certaines analyses) et mettre à jour les mentions d'information.

→ Sous-traitance non encadrée contractuellement (CloudSecure, AdBoost) et transferts hors UE non identifiés.

→ Action recommandée : Auditer et formaliser les contrats de sous-traitance (art. 28) ; cartographier la localisation des données et mettre en place les garanties de transfert requises (clauses contractuelles types).

2. Priorité: Élevée

→ MFA non généralisé ; facteur humain (phishing) identifié comme vecteur de risque principal.

→ Action recommandée : Rendre le MFA obligatoire sur tous les accès aux données sensibles; déployer une campagne de sensibilisation au phishing pour l'ensemble des équipes.

→ Processus de gestion des violations non formalisé.

-> Action recommandée : Rédiger une procédure écrite de réponse à incident (rôles, astreinte, modèles de notification CNIL/personnes) à partir du scénario testé.

3. Priorité: Moyenne

→ Registre des traitements incomplet (traitements internes non cartographiés)

→ Action recommandée: Étendre le registre à l'ensemble des traitements de X-Corp (RH, comptabilité, etc.) via des entretiens avec chaque service.

→ Gestion des consentements marketing peu maîtrisée ; volume élevé de demandes de droit d'accès.

→ Action recommandée : Déployer un outil de gestion des consentements (opt-in dédié pour AutoMail) et un portail structuré pour le traitement des demandes de droits.

4. Conclusion

X-Corp dispose d'une base de conformité réelle, gouvernance en place, sécurité technique robuste, mais des angles morts significatifs subsistent, en particulier sur l'encadrement de la sous-traitance, les transferts de données et la cohérence des bases légales retenues. Le plan d'action ci-dessus, s'il est mis en œuvre selon les échéances proposées, permettrait de porter la conformité de X-Corp d'un niveau partiel à un niveau satisfaisant sur l'ensemble des domaines audités.

[Sommaire](#)

#01